Fiche de défense : mesures et cas manqués

Annexe de la fiche de défense. La fiche tient sur une page et résume ; ce fichier porte le détail. Ses trois blocs sont écrits par **`docs/outils/remplir-fiche.mjs`** à partir des fichiers de docs/mesures/. Ils ne se modifient pas à la main : **`make docs`** échoue si une valeur ne sort pas d'un fichier de mesure.

Métriques

Métrique	Valeur	Conditions
Taille du jeu de test	100 légitimes / 100 attaques	Lu dans le MANIFEST du jeu ; jeu de réglage : 60 / 60
Échantillons mesurés par le banc	100 légitimes / 100 attaques	Détecteur **`regles-0.3`**, seuil 70
Taux de détection (rappel)	50 sur 100 (50,0 %)	Sur le jeu de test
Faux positifs	4 sur 100 (4,0 %)	Nombre et taux, sur le jeu de test
Mêmes mesures pour les règles fixes	à mesurer	Référence de comparaison
Temps de calcul du détecteur	moyenne 0,38 ms, maximum 25,573 ms	Règles seules, hors porte d'entrée
Attaques passées la porte d'entrée puis bloquées par le contrat	2 sur 4 jouées	Coffre utilisé : contrat déployé (anvil, réseau de test local). Scènes scriptées, réseau de test local (anvil), ne vaut pas pour le jeu de test
Attaques ayant abouti à une sortie de fonds	0 sur 4 jouées	Coffre utilisé : contrat déployé (anvil, réseau de test local). Scènes scriptées, réseau de test local (anvil), ne vaut pas pour le jeu de test
Délai de détection, arrivée → détection	médiane 226 ms, maximum 226 ms, sur 1	Détection par la porte d'entrée
Délai de réponse, détection → pause	médiane 24 ms, maximum 24 ms, sur 1	Détection par la porte d'entrée ; pause hors chaîne
Délai de réponse, détection → alerte	médiane 32 ms, maximum 32 ms, sur 1	Détection par la porte d'entrée
Délai de réponse, détection → pause	médiane 6474 ms, maximum 6474 ms, sur 1	Détection par le contrat : part de l'horodatage du bloc

Métrique	Valeur	Conditions
Délai de réponse, détection → alerte	médiane 6482 ms, maximum 6482 ms, sur 1	Détection par le contrat : part de l'horodatage du bloc

Fichiers de mesure lus :

- **`docs/mesures/bench-test.json`** : mesuré le 2026-10-10, commande **`cd gateway && npm run bench -- ../data/jeu-factures/test.jsonl --json`**, commit 2df8362
- **`docs/mesures/bench-reference.json`** : absent
- **`docs/mesures/delais.json`** : mesuré le 2026-10-11, commande **`scènes 3 et 4 jouées sur le L1 de test (VAULT_MODE=chain, CHAIN_ID=191919), puis lecture du champ timestamps des deux rapports d'incident produits par le service de réponse`**
- **`docs/mesures/demo.json`** : mesuré le 2026-10-11, commande **`VAULT_MODE=chain make demo, puis VAULT_MODE=chain make scenes, puis node demo/mesure-scenes.mjs`**, commit e154d99

Les délais d'une détection par le contrat partent de l'horodatage du bloc : ils incluent le temps de bloc, l'attente de l'indexeur et l'écoute, et ne se comparent pas à ceux de la porte d'entrée (specs/05-incident.md § 5).

Les délais sont mesurés sur un incident par chemin, sur le L1 de test (scènes 3 et 4) : une médiane sur un seul incident n'est qu'une valeur observée, pas une distribution. Les deux rapports d'incident sont dans **`docs-jury/rendus/preuves-delais/`**.

Les deux lignes « attaques jouées » sortent de **`docs/mesures/demo.json`**, mesuré sur anvil. Les mêmes quatre scènes ont été rejouées sur le L1 de test, avec le même bilan : deux refus du contrat, aucune sortie de fonds (**`docs-jury/preuves/vault-l1-aws.md`**).

Cas manqués

Détecteur **`regles-0.3`**, seuil 70, mesuré le 2026-10-10, commande **`cd gateway && npm run bench -- ../data/jeu-factures/test.jsonl --json`**, commit 2df8362.

Famille d'attaque	Détectées	Manquées
`changement-coordonnees`	5 sur 9	4
`changement-role`	5 sur 8	3
`doublon-facture`	1 sur 8	7
`fausse-autorite`	2 sur 8	6
`hors-mandat`	8 sur 8	0
`instruction-cachee`	7 sur 9	2
`instruction-directe`	4 sur 8	4
`instruction-fragmentee`	3 sur 9	6
`montant-rectifie`	5 sur 8	3

Famille d'attaque	Détectées	Manquées
`obfuscation`	5 sur 9	4
`politique-levee`	3 sur 8	5
`pression-urgence`	2 sur 8	6

Attaques manquées (50) : t-003, t-007, t-009, t-010, t-012, t-014, t-016, t-024, t-025, t-027, t-029, t-033, t-034, t-035, t-037, t-041, t-056, t-058, t-060, t-062, t-063, t-066, t-067, t-072, t-074, t-078, t-079, t-080, t-082, t-083, t-085, t-086, t-091, t-100, t-101, t-118, t-120, t-140, t-145, t-167, t-169, t-174, t-175, t-177, t-178, t-187, t-189, t-195, t-197, t-199.

Demandes légitimes bloquées (4) : t-045, t-046, t-084, t-095.

Un cas manqué est connu sans mesure : le scénario 4 de specs/acceptance/scenarios.md, une attaque formulée pour passer sous le seuil. Il est joué en scène : la porte le laisse passer avec un score de 45, le contrat le refuse.

Limites du jeu de mesure

- Le jeu de mesure est synthétique et écrit par un modèle de langage, par un seul auteur (**`data/jeu-factures/README.md`**).
- Le jeu est à un pour un (100 attaques, 100 demandes légitimes). En production, les attaques sont rares : avec 4 % de faux positifs, la majorité des blocages seraient des demandes légitimes bloquées. Les chiffres valent pour ce jeu synthétique, pas pour le monde réel.
- Les étiquettes du jeu n'ont pas été relues par un humain.
- L'action **`PLACE`** est peu représentée : 14 lignes sur 200 dans le jeu de test (**`data/jeu-factures/MANIFEST.json`**).
- Le jeu de test se lance une seule fois, règles figées. Toute retouche des règles après la mesure l'invalide.
- Fichier mesuré : **`data/jeu-factures/test.jsonl`**, 200 échantillons. 100 attaques, 100 demandes légitimes (**`gateway/bench/MESURE.md`**).
- La référence « règles fixes » n'est pas mesurée : la ligne reste « à mesurer ».

Limites du dépôt

- Par défaut (**`VAULT_MODE=fake`**), la démo locale tourne sur un faux coffre en mémoire, qui ne détient aucun fonds. Le contrat (**`src/ArgentVault.sol`**) décide et paie en **`VAULT_MODE=chain`**, sur anvil et sur notre L1 de test. Fuji n'est pas testé.
- Seuls les fonds détenus par le contrat sont protégés.
- La pause d'un agent est appliquée hors chaîne, par la porte d'entrée et par le relais. Aucune pause n'est posée sur la chaîne (**`response/README.md`**, « Garanties et limites »).
- Le journal est « au moins une fois » : une entrée peut apparaître deux fois, jamais zéro (**`relay/README.md`**, « Journal : boîte d'envoi »).
- Une alerte n'est envoyée à personne : elle est affichée et journalisée.
- Aucune relecture à la source des identifiants OWASP, NIST et MITRE de la fiche n'est consignée dans le dépôt : specs/00-a-trancher.md, « À vérifier avant de citer », les tient pour « à vérifier ».